Case Study - 2

PAGE No.
DATE / /

A university uses an OS - based examination management system to store student records, examination marks, faculty details & question papers. The system has three main user groups students, faculty & Admin. students should be able to view only their own records & enter or modify marks. Admin manage users accounts, permission & system config.

The university has assigned permission through roles, but an audit review identifies the following events.

- At 10:00, the account student 07 has three failed login attempts.
- At 10:03, student07 successfully login.
- At 10:04, student07 attempts to open exammarks.xlsx, which contains marks for an entire class
- At 10:05, the ~~staff~~ system records an attempts ~~to open~~ modification of exammarks.xlsx by student 07.
- At 10:15 Faculty02 modifies mark in ExamMark.xlsx & saves the files successfully.
- At 10:20 an admin discovers that a former faculty member's acc is still active.

PAGE No.
DATE / /

. The audit log is stored on the same server & users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integerity & users with broad permissions may be able to modify or delete it.

Questions

q1) Identify the main security problems in the case study.
[List at least four risk or weaknesses indicated by the scenario]

q2) Explain the difference between authentication & authorization using student.or as an example. (Distinguish identity verification from permission checking)

q3) Recommend an access - control policy for students, faculty & admin. Justify your choice. (consider how permissions should be assinged & managed)

q4) Prepare a suitable Access Access control List for ~~ExamMark.xsls~~ each user)

PAGE No.
DATE / /

Q5) Explain how the the principle of least Privilege should be applied in this system.
(state what each group needs to do & which unnecessary permissions should be removed)

Q6) Interpret the audit events from 10:00 to 10:05. What should the security team do next? (Explain why the sequence is suspicious without assuming that it proves an attack.

Q7) Identify at least five events that should be recorded in audit logs.
(include login, file, acc, permission & / or admin events)

Q8) Explain why the audit log must be protected & recommend two ways to protect them. (consider unauthorised modification, deletion & investigation).

Q9) What action should be taken regarding the former faculty member's active account? Explain (Relate your answer to account management & access removal).

Q10) Suggest a practical incident - response & corrective-action plan for the university. (Include investigation, access review, policy changes & follow up monitoring.)

PAGE No.
DATE / /

Answers :- Case study 2

A1) Four risk are:

i) 10:00 : student07 triggered 3 consecutive failed logins before getting in which may indicate unauthorized login.

ii) Immediatly after, the user attempted to open ExamMarks.xlsx

iii) Edit logs flags a direct attempt by student07 to modify values inside the marks file.

iv) separate findings : An ex faculty account is still active on system & needs to be removed.

A2) Authentication :- when student07 signs in at 10:03 with their username & pass, the system verifies their identity & grants entry.

Authorization :- Once logged in, the system enforces access rules. Even though student07 is verified, authorization restricts them to their own records & blocks them from opening or editing ExamMarks.xlsx

Example :-

A3) The university should implement Role Based Access control.
students only have visibility to their personel records.

Faculty get access exclusively for the classes they teach.

Admin maintains user lifecycle & system settings rathes than day-to day grade editing.

RBAC is suitable because it assigns permission according to the roles.

A4)

Task	Student	Faculty	Admin
View own marks	Allow	Allow	All (if required
View all students marks	Deny	Allow	Allow
Enter or modify marks	Deny	Allow	Allow
Delete examination records	Deny	Deny	Allow
Manage User accounts	Deny	Deny	Allow
View audit logs	Deny	Deny	Allow
		~~Deny~~	~~Allow~~

A5) Students should only have access to their own academic records.

Faculty have access to their assigned course.

Admin recieve only the permision required to manage accounts.

A6) Three failed login attempt by student 07 at 10:00, then logs in at 10:03, & attempts to modify ExamMarks.xlsx at 10:04 - 10:05.

The security team should:
i) Review audit logs
ii) Verify if the logins were legit
iii) check wether any records changed
iv) temperorarily restrict the account
v) Preserve audit log & investigate.

A7) i) Login & logout events.
ii) File access events
iii) Account Management events
iv) Admin activity
v) security alerts

A8) It must be protected because they provide evidence of user activity & security incidents.

Two ways to protect:-
i) Restrict access, only security personnel can access.
ii) Store logs on separate, centralised server.

PAGE No.
DATE / /

A9) i) Disable the account
ii) Remove access to university portal
iii) Review recent login history
iv) Preserve audit logs
v) Update account management

A10) i) Identification :- Examine audit logs & identify acti
ii) Containment :- Restrict compromise account
iii) Investigation :- Preserve audit logs.
iv) Recovery :- Restore affected records.
v) Policy changes :- Role based access control
vi) Follow up monitoring :- monitor audit logs.
vii) Documentation :- Inform higher authority.